UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTÂNCIA

DISCIPLINA

# ETHICAL HACKER

SEGURANÇA DA INFORMAÇÃO
COM PROPÓSITO E RESPONSABILIDADE



PROFESSOR
**RODOLFO TERRA**



UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTÂNCIA

# O que veremos nesta aula?

## 01 Cenário atual da Segurança da Informação



- Importância da informação
- Dependência das organizações
- Principais ameaças e impactos
- Exemplos do dia a dia

## 02 Os três pilares: CIA




- Confidencialidade
- Integridade
- Disponibilidade
- Exemplos práticos
- Identificação de incidentes

## 03 O que é um Hacker?



- Hacker, Cracker e Ethical Hacker
- White Hat x Black Hat
- A mesma técnica, diferentes finalidades
- Mitos e verdades

## 04 Autorização e Teste de Invasão (Pentest)



- Importância da autorização
- Definição de escopo
- O que é um Pentest
- Etapas de um teste de segurança
- Exemplo de resultado

## 05 Responsabilidades, Ética e Legalidade



- Papel do Ethical Hacker
- Limites éticos e legais
- Responsabilidades profissionais
- Proteção de dados e legislação
- Boas práticas de conduta

## 06 Estudo de caso e Encerramento



- Discussão de um caso prático
- Reflexões sobre conduta profissional
- Principais aprendizados da aula
- Próximos passos da disciplina

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTANCIA

BLOCO 01

# Introdução e cenário digital

A importância da Segurança da Informação no mundo atual.



UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTÂNCIA

# Por que a informação precisa ser protegida?

Hoje, praticamente todas as organizações dependem da tecnologia e da informação para funcionar.




## Banco

- Contas e saldos
- Transações financeiras
- Dados dos clientes
- Contratos e serviços



## Hospital

- Prontuários
- Exames e diagnósticos
- Prescrições médicas
- Dados dos pacientes



## Comércio

- Vendas e pedidos
- Estoque de produtos
- Dados dos clientes
- Pagamentos
- Informações financeiras




## Universidade

- Dados dos alunos
- Notas e histórico acadêmico
- Documentos e pesquisas
- Sistemas acadêmicos
- Dados de professores e funcionários

**A informação é um dos ativos mais importantes** de qualquer organização.
Sua exposição, alteração ou indisponibilidade pode gerar **prejuízos financeiros, operacionais e reputacionais**.

**Professor Rodolfo Terra** | Disciplina: Ethical Hacker | Linkedin: /in/rodolffoterra/ | Github: github.com/rodolffoterra/

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTÂNCIA

# Uma empresa, três problemas de segurança

Imagine um supermercado que depende de sistemas para gerenciar produtos, vendas, estoque, fornecedores e finanças.




## 01 Acesso não autorizado a dados financeiros

Um funcionário consegue acessar informações financeiras da empresa, sem possuir autorização.




## 02 Alteração indevida de preço

O preço de um produto é alterado no sistema de R$ 100,00 para R$ 1,00, sem autorização.




## 03 Sistema de vendas indisponível

O sistema de vendas fica fora do ar durante todo o sábado, impossibilitando o registro de compras.




**Esses três acontecimentos representam o mesmo tipo de problema de segurança?**

Qual princípio da Segurança da Informação está sendo afetado em cada situação?

**Professor Rodolfo Terra** | Disciplina: Ethical Hacker | Linkedin: /in/rodolffoterra/ | Github: github.com/rodolffoterra/

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTÂNCIA

BLOCO 02

# Confidencialidade, Integridade e Disponibilidade

Os três pilares da Segurança da Informação



UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTÂNCIA

# Os três pilares da Segurança da Informação

A Segurança da Informação se baseia em três princípios fundamentais que garantem a proteção das informações nas organizações.

## Confidencialidade

A informação deve ser acessada somente por quem possui autorização.

- Controle de acesso
- Autenticação e autorização
- Proteção contra vazamento de dados

## Integridade

A informação deve permanecer correta e não pode ser alterada indevidamente.

- Dados confiáveis e consistentes
- Controle de alterações
- Rastreabilidade e logs
- Prevenção contra modificações não autorizadas




## Disponibilidade

A informação e os sistemas precisam estar disponíveis quando forem necessários.

- Sistemas acessíveis e operacionais
- Alta disponibilidade
- Plano de contingência
- Proteção contra interrupções (Ex.: ataques de negação de serviço)

**Professor Rodolfo Terra** | Disciplina: Ethical Hacker | Linkedin: /in/rodolffoterra/ | Github: github.com/rodolffoterra/

# Confidencialidade — Quem pode acessar?

A informação deve ser acessada somente por quem possui autorização.




## Autenticação

Confirma a identidade do usuário.

- Senha
- Autenticação multifator (MFA)
- Certificados
- Biometria

## Autorização

Define o que o usuário pode acessar.

- Permissões por perfil (ex.: RH, Financeiro)
- Controle de acesso (ACL)
- Princípio do menor privilégio
- Segmentação de dados

## Importante

Vizualizar informações sigilosas sem permissão **já representa um incidente de segurança**, mesmo que não haja alteração dos dados.

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTÂNCIA

# Integridade — A informação continua correta?

A informação deve permanecer correta, completa e confiável, sem ser alterada de forma indevida.

**Antes da alteração**




**Depois da alteração indevida**




## O que é Integridade?

Garantir que os dados não sejam alterados de forma não autorizada, mantendo sua exatidão, consistência e confiabilidade.

## Como proteger a integridade?

- Permissões e controle de acesso
- Registros de logs de alterações
- Validações e regras de negócio
- Mecanismos de verificação (checksums, assinaturas)

## Exemplos de impacto

- Preços alterados em produtos
- Notas acadêmicas modificadas
- Saldos financeiros incorretos
- Cadastros de clientes adulterados

**Professor Rodolfo Terra** | Disciplina: Ethical Hacker | Linkedin: /in/rodolffoterra/ | Github: github.com/rodolffoterra/

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTÂNCIA

# Você consegue identificar o princípio afetado?

Analise as situações abaixo e escolha o princípio da Segurança da Informação que foi comprometido.

**01** **Um invasor visualizou dados sigilosos, mas não alterou nada.**




- ○ Confidencialidade
- ○ Integridade
- ○ Disponibilidade

**02** **O saldo de uma conta foi modificado indevidamente.**




- ○ Confidencialidade
- ○ Integridade
- ○ Disponibilidade

**03** **O sistema acadêmico ficou inacessível durante a matrícula.**




- ○ Confidencialidade
- ○ Integridade
- ○ Disponibilidade

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTÂNCIA

# Você consegue identificar o princípio afetado?

Analise as situações abaixo e escolha o princípio da Segurança da Informação que foi comprometido.

## 01 Um invasor visualizou dados sigilosos, mas não alterou nada.




- (●) Confidencialidade
- ( ) Integridade
- ( ) Disponibilidade

**Correto!**
A informação foi acessada por alguém sem autorização, comprometendo a confidencialidade.

## 02 O saldo de uma conta foi modificado indevidamente.




- ( ) Confidencialidade
- (●) Integridade
- ( ) Disponibilidade

**Correto!**
A informação deixou de representar o valor correto.

## 03 O sistema acadêmico ficou inacessível durante a matrícula.




- ( ) Confidencialidade
- ( ) Integridade
- (●) Disponibilidade

**Correto!**
O sistema ficou inacessível, comprometendo a disponibilidade.

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTÂNCIA

BLOCO 03

# Conceitos e classificações de hackers

Conheça os principais tipos de hackers, suas motivações e como atuam no contexto da segurança da informação.



## WHITE HAT

Atua de forma ética para identificar vulnerabilidades e fortalecer a segurança.

## GRAY HAT

Atua em uma zona cinzenta, podendo explorar vulnerabilidades sem autorização, nem sempre com intenções maliciosas.

## BLACK HAT

Atua de forma ilegal, explorando vulnerabilidades para obter vantagens indevidas e causar danos.

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTANCIA

# Afinal, o que é um Hacker?

Hacker é uma pessoa que possui **conhecimentos** técnicos em tecnologia da informação e utiliza essas habilidades para **entender, explorar, analisar** e resolver problemas em sistemas, podendo atuar de forma ética ou maliciosa.



## Todo hacker é criminoso?



### Curiosidade técnica

Interesse em entender como as tecnologias funcionam.

### Análise de sistemas

Estudo de tecnologias, arquiteturas e comportamentos.

### Identificação de falhas

Busca por vulnerabilidades e pontos de melhoria em sistemas.

### Resolução de problemas

Criação de soluções, aprimoramento de sistemas e aumento da segurança.

**Professor Rodolfo Terra** | Disciplina: Ethical Hacker | Linkedin: /in/rodolffoterra/ | Github: github.com/rodolffoterra/

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTANCIA

# Hacker, Cracker e Ethical Hacker

Técnicas semelhantes podem ser utilizadas em contextos diferentes. O diferencial está na autorizaçao, finalidade e conduta.



## Hacker

Pessoa com conhecimento técnico para investigar, explorar e analisar sistemas, buscando entender como eles funcionam.

- Curiosidade e aprendizado
- Analisa sistemas e tecnologias
- Busca entender como as coisas funcionam



## Cracker

Termo utilizado na apostila para quem compromete sistemas de forma maliciosa, explorando vulnerabilidades para obter vantagem ou causar danos.

- Atua de forma ilegal
- Explora falhas para obter acesso indevido
- Pode causar prejuízos e comprometer sistemas e dados



## Ethical Hacker

Profissional que utiliza técnicas de segurança ofensiva com autorização e finalidade defensiva, ajudando organizações a identificar vulnerabilidades e melhorar a segurança.

- Atua com autorização
- Identifica vulnerabilidades
- Contribui para fortalecer a segurança da organização

**Professor Rodolfo Terra** | Disciplina: Ethical Hacker | Linkedin: /in/rodolffoterra/ | Github: github.com/rodolffoterra/

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTÂNCIA

# White Hat × Black Hat

O uso de uma ferramenta não torna uma atividade ética.
O contexto e a autorização são fundamentais.




## White Hat

Atuação autorizada, limites definidos e objetivo de fortalecer a segurança.

**Atua com autorização**
Realiza testes e análises com consentimento.

**Segui normas e políticas**
Respeita limites legais e éticos.

**Objetivo defensivo**
Identifica vulnerabilidades para melhorar a segurança.



## Black Hat

Atuação maliciosa ou não autorizada, visando comprometer sistemas.

**Atua sem autorização**
Invade sistemas sem consentimento.

**Explora vulnerabilidades**
Busca obter acesso indevido, roubar dados ou causar danos.

**Objetivo malicioso**
Utiliza técnicas para benefício próprio ou de terceiros, comprometendo pessoas e organizações.

**Professor Rodolfo Terra** | Disciplina: Ethical Hacker | Linkedin: /in/rodolffoterra/ | Github: github.com/rodolffoterra/

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTÂNCIA

# A mesma técnica, duas finalidades

O conhecimento e as ferramentas podem ser os mesmos. O que diferencia é a autorização, a finalidade e a conduta.

## Ethical Hacker (White Hat)

Atua com autorização, dentro de limites definidos, com o objetivo de fortalecer a segurança.

- Possui autorização para testar
- Utiliza a técnica de análise de vulnerabilidades
- Registra os achados e gera um relatório técnico
- **Resultado**: A organização corrige a falha e melhora sua segurança.






**Mesma técnica**
Análise de vulnerabilidades

## Cracker (Black Hat)

Atua de forma maliciosa ou não autorizada, visando comprometer sistemas para obter vantagem.

- **Não possui autorização**
- Utiliza a mesma técnica de análise de vulnerabilidades
- Explora a falha para obter acesso indevido
- **Resultado**: Comprometimento de dados, prejuízos financeiros e danos à organização.



**Professor Rodolfo Terra** | Disciplina: Ethical Hacker | Linkedin: /in/rodolffoterra/ | Github: github.com/rodolffoterra/

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTÂNCIA

BLOCO 04

# Autorização, escopo e Pentest



UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTÂNCIA

# Bloco 4 — Autorização, escopo e Pentest

Testes de invasão devem ser realizados com autorização, escopo bem definido e metodologia adequada.




## 01 Autorização

O teste deve ser formalmente autorizado pelo responsável, definindo objetivos, limites e regras.

## 02 Escopo

Define o que pode e o que não pode ser testado (sistemas, redes, aplicações, períodos e restrições).

## 03 Execução do Pentest

Utilização de técnicas e ferramentas para identificar vulnerabilidades, seguindo a metodologia e os limites do escopo.

## 04 Relatório e recomendações

Apresenta os achados, o nível de risco e recomendações para correção e melhoria da segurança.

**Importante!**
Testes de invasão sem autorização podem ser considerados atividade ilegal, mesmo que utilizem as mesmas técnicas de um pentest.

**Contexto, autorização e finalidade**
são os fatores que diferenciam um teste ético e legal de uma invasão maliciosa.

Professor Rodolfo Terra | Disciplina: Ethical Hacker | Linkedin: /in/rodolffoterra/ | Github: github.com/rodolffoterra/

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTANCIA

# Boa intenção não substitui autorização

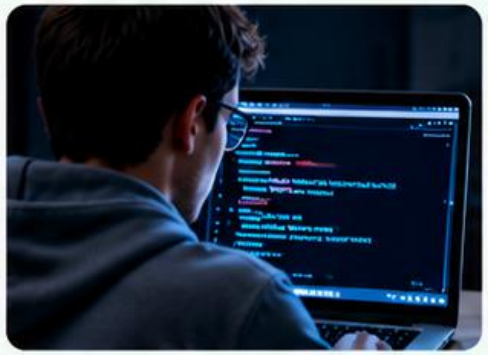
Mesmo com boas intenções, testes de segurança devem ser realizados apenas com autorização válida e limites definidos.

## 01 O estudante identifica uma possível falha




Durante seus estudos, o estudante identifica um comportamento incomum no site de uma empresa que pode indicar uma vulnerabilidade.

## 02 Decide explorar para confirmar



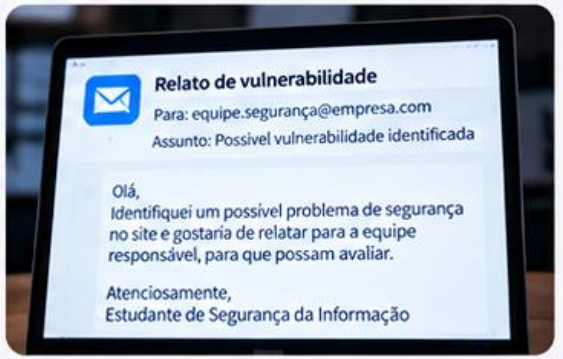
Com a intenção de ajudar, ele decide explorar a falha para comprovar que ela existe, sem solicitar autorização da empresa.

## 03 Consequências possíveis




Mesmo com boa intenção, a exploração sem autorização pode causar impactos negativos e resultar em consequências legais e disciplinares.

## 04 Qual seria a conduta correta?




A conduta correta é comunicar a empresa pelo canal adequado, sem explorar a falha, aguardar a resposta e seguir as orientações da equipe responsável.

## A boa intenção torna o teste permitido?

Não. A autorização é um requisito fundamental. O profissional deve possuir autorização válida e limites bem definidos antes de executar testes de segurança.

## Principais aprendizados

- Boa intenção não substitui autorização.
- Testes de segurança devem seguir escopo e limites definidos.
- A comunicação responsável contribui para a melhoria da segurança.
- O uso de uma ferramenta ou técnica, por si só, não torna a atividade ética.

**Professor Rodolfo Terra** | Disciplina: Ethical Hacker | Linkedin: /in/rodolffoterra/ | Github: github.com/rodolffoterra/

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTÂNCIA

# O que é escopo em um teste de segurança?

O escopo define os limites do teste, o que pode e o que não pode ser feito, garantindo uma atuação segura e responsável.

**01 Sistemas e endereços autorizados**

Quais sistemas, ambientes, domínios e endereços IP podem ser testados.

**02 Técnicas e atividades permitidas**

Quais técnicas, ferramentas e tipos de testes podem ser utilizados (ex.: varredura, teste de aplicação, engenharia social autorizada).

**03 Atividades expressamente proibidas**

O que não pode ser realizado, como acesso a dados reais, negação de serviço, alterações em produção, entre outros.

**DOCUMENTO DE ESCOPO**
TESTE DE SEGURANÇA

**04 Datas e horários**

Período de execução do teste, com início e término definidos para evitar impactos na operação.

**05 Responsáveis e contatos**

Equipe envolvida, responsáveis do cliente e canais de comunicação para dúvidas e situações emergenciais.

**06 Critérios de interrupção e entregáveis**

Situações que exigem a interrupção imediata do teste e quais são os resultados esperados (ex.: relatório técnico com achados e recomendações).




**Por que o documento de escopo é importante?**
Ele protege o cliente, o profissional e a operação, alinhando expectativas, reduzindo riscos e garantindo que o teste seja realizado de forma ética, legal e segura.

Professor Rodolfo Terra | Disciplina: Ethical Hacker | Linkedin: /in/rodolffoterra/ | Github: github.com/rodolffoterra/

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTANCIA

# O que é um Pentest?

Penetration Test (Teste de Invasão) é uma avaliação autorizada que simula ações de um atacante para identificar e, quando permitido, demonstrar vulnerabilidades em sistemas, redes e aplicações.

## Objetivo

Identificar vulnerabilidades e fornecer recomendações para melhorar a segurança, antes que sejam exploradas por atacantes reais.

### 01 Sistema alvo definido no escopo



Os sistemas, redes ou aplicações são definidos no documento de escopo, com limites e regras claras.

### 02 Avaliação controlada



São utilizadas técnicas e ferramentas para simular, de forma controlada e autorizada, ações que um atacante poderia realizar.

### 03 Vulnerabilidades identificadas



São encontradas e, quando permitido pelo escopo, exploradas e comprovadas, demonstrando o impacto real da vulnerabilidade.

### 04 Relatório e recomendações



- Descrição da vulnerabilidade
- Impacto identificado
- Recomendações de correção

Os resultados são documentados em um relatório técnico, com evidências, nível de risco e recomendações para correção e melhoria da segurança.

## Encontrar uma possível falha × Comprovar a exploração

Identificar uma possível vulnerabilidade é o primeiro passo. Comprovar sua exploração significa demonstrar, de forma prática e controlada, que a falha pode ser utilizada para obter acesso, dados ou causar algum impacto.

## Autorização e limites

O pentest só deve ser realizado com autorização válida e dentro do escopo definido. Testes fora do escopo, mesmo com boa intenção, podem causar prejuízos e gerar responsabilidades legais e disciplinares.

**Professor Rodolfo Terra** | Disciplina: Ethical Hacker | Linkedin: /in/rodolffoterra/ | Github: github.com/rodolffoterra/

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTÂNCIA

# Etapas de um Pentest

O teste de invasão segue um processo estruturado, da autorização à comunicação dos resultados.

## 01 Autorização

Obtenção de autorização formal do cliente para realizar o teste, definindo responsáveis e base legal.




## 02 Escopo

Definição dos sistemas, endereços, técnicas permitidas, atividades proibidas, período de teste e regras.



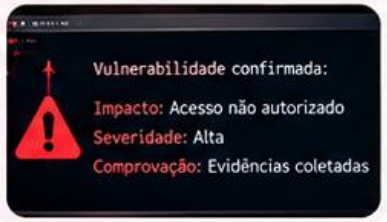

## 03 Avaliação

Execução das atividades de teste, utilizando técnicas e ferramentas dentro do escopo definido.




## 04 Validação

Confirmação das vulnerabilidades encontradas, quando permitido, demonstrando o impacto real.




## 05 Relatório

Documentação dos achados, nível de risco, evidências e conclusão do teste.




## 06 Recomendações

Propostas de correção e melhorias para mitigar os riscos identificados, priorizadas por criticidade.




**Importante!**
A exploração de uma falha só deve ocorrer quando houver autorização expressa e dentro dos limites estabelecidos no escopo.

**Resultado**
O pentest não tem como objetivo causar danos, mas identificar vulnerabilidades de forma controlada e fornecer informações para melhorar a segurança.

Professor Rodolfo Terra | Disciplina: Ethical Hacker | Linkedin: /in/rodolffoterra/ | Github: github.com/rodolffoterra/

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTANCIA

# Exemplo de resultado de um Pentest

Veja como um achado técnico é apresentado em um relatório de teste de invasão, conectando o problema, o impacto e a recomendação.

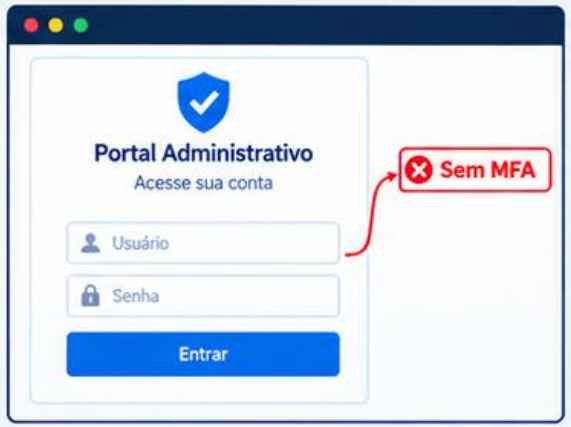
ACHADO #01

## Autenticação sem MFA

**Sistema**
Portal administrativo da Empresa Exemplo Ltda.

**Risco**
Aumenta a exposição a acessos indevidos quando credenciais são comprometidas.

**Recomendação**
Implementar autenticação multifator para contas administrativas.




Observação: O acesso é liberado apenas com usuário e senha, sem a exigência de um segundo fator de autenticação.

**Lembre-se:**
O que torna uma atividade ética não é a técnica utilizada, mas sim a autorização, o contexto e a finalidade.

### O que foi identificado?

O portal administrativo permite o acesso com apenas usuário e senha, sem a utilização de autenticação multifator (MFA).

### Qual o impacto?

Caso as credenciais sejam comprometidas (por exemplo, via phishing ou vazamento), um atacante pode acessar o sistema com privilégios administrativos, aumentando o risco de alteração de dados, criação de usuários e movimentações indevidas.

### Qual a recomendação?

Implantar autenticação multifator para todas as contas administrativas, exigindo um segundo fator de verificação (ex.: aplicativo autenticador, token ou SMS).

### Objetivo do relatório

O relatório não tem como objetivo demonstrar a capacidade de invasão, mas sim orientar a redução de riscos e fortalecer a segurança do ambiente.

Professor Rodolfo Terra | Disciplina: Ethical Hacker | Linkedin: /in/rodolffoterra/ | Github: github.com/rodolffoterra/

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTÂNCIA

BLOCO 05

# Responsabilidades, ética e legalidade



UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTANCIA

# O papel do Ethical Hacker na organização

O Ethical Hacker atua identificando e ajudando a corrigir vulnerabilidades que podem surgir em diferentes áreas da organização, e não apenas em falhas de código.

## 01 Software

Falhas de desenvolvimento, códigos inseguros, validações inadequadas e dependências vulneráveis.



## 02 Configurações

Serviços mal configurados, permissões excessivas, equipamentos expostos e configurações padrão não alteradas.






## 03 Processos

Políticas de segurança insuficientes, ausência de controles, falhas de governança e processos mal definidos.



## 04 Pessoas

Comportamentos de risco, falta de conscientização, engenharia social e erros humanos no dia a dia.



## Principais responsabilidades

- **Identificar** vulnerabilidades em sistemas, redes, processos e pessoas.
- **Simular** ações de um atacante de forma autorizada e dentro do escopo.
- **Ajudar** a **corrigir** e priorizar os riscos encontrados.
- **Contribuir** para a melhoria contínua da segurança da informação.
- **Atuar** de forma ética, legal e responsável, protegendo os interesses da organização.

## Objetivo final

O Ethical Hacker não busca causar danos, mas sim identificar vulnerabilidades e apoiar a organização na redução de riscos, fortalecendo a segurança, a continuidade do negócio e a proteção dos dados.

Professor Rodolfo Terra | Disciplina: Ethical Hacker | Linkedin: /in/rodolffoterra/ | Github: github.com/rodolffoterra/

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTÂNCIA

# Encontrar uma vulnerabilidade é diferente de corrigi-la

O teste de segurança identifica e demonstra as vulnerabilidades, mas a correção é realizada pela equipe responsável, seguindo processos internos da organização.

## Hacker ético

Avalia, identifica, documenta e recomenda.

01 Identifica a vulnerabilidade dentro do escopo autorizado.

02 Valida e, quando permitido, demonstra o impacto.

03 Documenta o achado com evidências.

04 Classifica o risco.

05 Recomenda ações de correção.




**Relatório de achados**

Vulnerabilidades identificadas, evidências, nível de risco e recomendações.

## Equipe responsável

Planeja, implementa e valida as correções.

01 Analisa o relatório e prioriza os achados.

02 Planeja e implementa as correções.

03 Realiza testes internos e valida as mudanças.

04 Solicita novos testes (quando previsto no contrato) para confirmar a correção.



### O papel do contrato

O contrato de testes de segurança define se o profissional participa apenas da identificação e recomendação ou também de atividades de remediação e novos testes.

### Importante

O objetivo do pentest é orientar a redução de riscos. A correção das falhas é responsabilidade da equipe designada pela organização, seguindo seus processos, políticas e prazos internos.

Professor Rodolfo Terra | Disciplina: Ethical Hacker | Linkedin: /in/rodolffoterra/ | Github: github.com/rodolffoterra/

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTANCIA

# Princípios éticos do profissional

O Ethical Hacker deve atuar com ética, responsabilidade e respeito, seguindo boas práticas e os limites definidos em contrato.

## 01 Confidencialidade



Proteger todas as informações acessadas durante o teste, evitando divulgação não autorizada.

## 02 Respeito ao escopo



Atuar apenas nos sistemas, técnicas e atividades autorizados, respeitando os limites definidos no contrato.

## 03 Responsabilidade



Evitar causar danos aos sistemas, serviços e dados da organização, atuando de forma segura e controlada.

## 04 Documentação



Registrar todas as atividades realizadas, evidências, achados e recomendações de forma clara e organizada.

## 05 Imparcialidade



Relatar os achados de forma objetiva e imparcial, baseada em evidências, sem exageros e sem tentações pessoais.

## 06 Respeito às pessoas



Agir com respeito, ética e profissionalismo, evitando expor ou culpabilizar indivíduos. O foco é identificar problemas, não procurar culpados.

### Objetivo

Contribuir para a melhoria da segurança da informação, protegendo a organização, seus dados e suas pessoas.

### Importante

A orientação da apostila é clara: o Ethical Hacker deve identificar problemas e oportunidades de melhoria, e não procurar culpados.

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTÂNCIA

# Legalidade e limites profissionais

A atuação do Ethical Hacker deve respeitar a legislação, os limites contratuais, as políticas da organização e o escopo definido para o teste de segurança.

## Legislação

A atuação deve respeitar as leis aplicáveis, como o Código Penal e a LGPD.




- Acesso indevido a sistemas é crime (Código Penal).
- A proteção de dados pessoais deve seguir a LGPD.
- O teste autorizado e dentro dos limites não caracteriza atividade ilegal.

## Contrato

Formaliza a autorização para o teste, definindo responsabilidades e limites.




- Define o objetivo do teste.
- Estabelece responsabilidades das partes.
- Determina a extensão das atividades autorizadas.

## Políticas

Diretrizes internas da organização guiam a execução do teste, assegurando alinhamento com a governança e a segurança.




- Política de segurança da informação.
- Política de uso aceitável.
- Regras para testes de segurança.
- Aprovações internas e comunicação.

## Escopo

Define o que pode e o que não pode ser testado, incluindo sistemas, técnicas, prazos e restrições.




- Sistemas e endereços autorizados.
- Técnicas e atividades permitidas.
- Atividades proibidas.
- Datas e horários.
- Responsáveis e contatos.

## Importante

Realizar testes de segurança sem autorização, fora do escopo ou em desacordo com a legislação pode resultar em sanções legais e prejuízos para o profissional e para a organização.

## Atuação segura e responsável

O Ethical Hacker atua dentro da legalidade, dos limites contratuais, seguindo as políticas da organização e o escopo definido, contribuindo para a melhoria da segurança e a proteção dos dados.

Professor Rodolfo Terra | Disciplina: Ethical Hacker | Linkedin: /in/rodolffoterra/ | Github: github.com/rodolffoterra/

UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTÂNCIA

BLOCO 06

# Discussão e encerramento



UniCesumar
EDUCAÇÃO PRESENCIAL E A DISTANCIA

# Estudo de caso — O relatório que ninguém quer receber

Situação realista para discutir os desafios éticos na atuação do Ethical Hacker.

## Cenário

Um hacker ético identifica vulnerabilidades graves durante um Pentest autorizado em uma empresa fictícia.

Após a conclusão dos testes, o gerente de TI solicita que algumas delas sejam omitidas do relatório para evitar problemas com a diretoria.




## Pergunta para a turma

Qual deve ser a postura do profissional?

## Tempo de atividade

**2 minutos**
**Reflexão individual**
Pense em sua resposta.

→

**3 minutos**
**Compartilhamento**
Vamos ouvir algumas respostas da turma.

→

**2 minutos**
**Conclusão**
Síntese e explicação do professor.

## Orientação

01 O profissional deve preservar a integridade do relatório.

02 Comunicar os achados pelos canais previstos no contrato.

03 Seguir os procedimentos contratuais de escalonamento.

04 Não omitir informações relevantes sobre vulnerabilidades identificadas.

05 Manter a postura ética, profissional e transparente.

## Pontos de aprendizado

- A integridade do relatório é essencial para a credibilidade do trabalho.
- O profissional atua com base em escopo, contrato e responsabilidade ética.
- A omissão de achados relevantes pode expor a organização a riscos e gerar consequências legais e profissionais.
- O objetivo é contribuir para a melhoria da segurança, e não evitar desconfortos internos.

Professor Rodolfo Terra | Disciplina: Ethical Hacker | Linkedin: /in/rodolffoterra/ | Github: github.com/rodolffoterra/